FICHE 16- TRACER LES OPÉRATIONS

Tracer les opérations pour la détection d'anomalies, de dysfonctionnements ou d'incidents et disposer des informations utiles à leur traitement ou en cas de contentieux.

Afin de pouvoir **identifier un accès frauduleux** ou une **utilisation abusive** de données personnelles, ou de déterminer l'origine d'un incident, il convient d'enregistrer certaines des actions effectuées sur les systèmes informatiques. Les traces alors collectées sont également des éléments de preuve utiles pour la démonstration de la conformité[72].

Les précautions élémentaires

- **Prévoir un système de journalisation** (c'est-à-dire un enregistrement dans des fichiers journaux ou « *logs* ») des activités métier des utilisateurs (traces applicatives), des interventions techniques (y compris par les administrateurs), des anomalies et des évènements liés à la sécurité (traces techniques ou « système »).
- **Conserver ces évènements sur une période glissante comprise entre six mois et un an** (sauf, par exemple, en cas d'obligation légale portant sur cette durée de conservation, de besoin de gestion des contentieux, de contrôle interne ou encore d'un besoin identifié d'analyse post-incident).
- **Effectuer, pour les traces applicatives, un enregistrement des opérations de création, consultation, partage, modification et suppression** des données en conservant l'identifiant de l'auteur, la date, l'heure et la nature de l'opération ainsi que la référence des données concernées (pour en éviter la duplication).
- **Informer les utilisateurs**, par exemple lors de l'authentification ou de l'accès au système, de la mise en place du dispositif de journalisation, après information et consultation des instances représentatives du personnel.
- **Protéger les équipements de journalisation et les informations journalisées** pour empêcher les opérations non autorisées (ex. : en les rendant inaccessibles aux personnes dont l'activité est journalisée), les mésusages par des comptes habilités (ex. : en mettant en place une charte d'utilisation ou des alertes spécifiques) et l'écrasement des traces générées par les applicatifs concernés.
- S'assurer du bon fonctionnement du système de journalisation **en intégrant les équipements dans un outil de supervision et vérifier régulièrement la présence de journaux exploitables**.
- **S'assurer que les sous-traitants sont contractuellement tenus** de mettre en œuvre la journalisation conformément aux présentes recommandations et de notifier dans les plus brefs délais, toute anomalie ou tout incident de sécurité au responsable de traitement.
- **Analyser de manière active, en temps réel ou à court terme, les traces collectées pour être en mesure de détecter la survenue d'un incident** (voir la fiche n°19 - Gérer les incidents et les violations).

72 Articles 5.2 et 24.1 du RGPD.